

PONTIFÍCIA UNIVERSIDADE CATÓLICA DE GOIÁS
ESCOLA POLITÉCNICA E DE ARTES
GRADUAÇÃO EM ENGENHARIA DA COMPUTAÇÃO



PUC
GOIÁS

FLAELISNANDA DACIO
JÉSSICA RODRIGUES
LUDMILA LIMA
SAVIO REIS

COFRE AES

GOIÂNIA
2026

Sumário

Resumo	2
1 Introdução	2
2 Objetivos	3
2.1 Objetivo geral	3
2.2 Objetivos específicos	3
3 Arquitetura da Solução	3
4 Criptografia e Segurança	3
5 Fluxo de Funcionamento	4
6 Endpoints da API	4
7 Tratamento de Erros e Segurança Operacional	5
8 Testes e Validação	5
9 Conclusão	6

Resumo

Este trabalho apresenta o desenvolvimento de um sistema de cofre de senhas com foco em criptografia aplicada, autenticação por senha mestra e armazenamento seguro de dados sensíveis. A aplicação foi implementada em Python com FastAPI e integra-se ao Supabase para persistência dos dados. O projeto utiliza PBKDF2-HMAC-SHA256 para derivação de chaves e AES-GCM para cifragem dos segredos armazenados. O objetivo principal é demonstrar, de forma prática, a aplicação de conceitos de segurança da informação em sistemas de gerenciamento de credenciais.

1 Introdução

A segurança da informação é um tema central no desenvolvimento de sistemas digitais, especialmente quando se trata do armazenamento e gerenciamento de senhas e informações sensíveis. Em ambientes corporativos e acadêmicos, o vazamento de credenciais pode causar prejuízos financeiros, perda de reputação e comprometimento de sistemas.

Diante dessa necessidade, este projeto propõe a criação de um cofre de senhas com arquitetura de API REST, em que as informações sensíveis são protegidas antes de serem armazenadas em um banco de dados. O sistema permite que o usuário cadastre um cofre, defina uma senha mestra e armazene segredos como credenciais de acesso, URLs e dados de autenticação.

A solução implementada utiliza mecanismos criptográficos robustos, incluindo:

- PBKDF2-HMAC-SHA256 para derivação de chaves;
- AES-GCM para criptografia dos segredos;
- salt aleatório por cofre;
- nonce aleatório para cada operação de cifragem;
- autenticação de integridade por meio da etiqueta GCM;
- validação de senha mestra antes de acessar registros protegidos.

O objetivo geral do projeto é demonstrar, de forma prática e didática, como aplicar princípios de segurança em um sistema de armazenamento de senhas, respeitando as exigências de confidencialidade, integridade e autenticação.

2 Objetivos

2.1 Objetivo geral

Implementar um sistema de cofre de senhas seguro, com API REST, criptografia aplicada e validação de autenticação por senha mestra.

2.2 Objetivos específicos

- implementar derivação de chave por PBKDF2 com SHA-256;
- gerar sal aleatório para cada cofre;
- cifrar segredos usando AES-GCM;
- garantir integridade dos dados armazenados;
- autenticar cada operação protegida por meio da senha mestra;
- persistir os dados de forma segura no banco;
- validar o comportamento da aplicação por testes automatizados.

3 Arquitetura da Solução

A aplicação foi organizada em camadas, de modo a separar responsabilidades e facilitar manutenção e teste. A camada de API foi desenvolvida em FastAPI e é responsável por expor endpoints para criação, abertura, leitura, atualização e remoção de dados protegidos.

A camada de criptografia gera chaves, cifra e decifra segredos e valida a integridade dos registros. A camada de persistência acessa o banco Supabase e armazena os dados criptografados juntamente com metadados essenciais para a operação do sistema.

4 Criptografia e Segurança

A senha mestra do usuário não é armazenada diretamente. Em vez disso, ela é usada como entrada para a função PBKDF2-HMAC-SHA256, que gera uma chave de 32 bytes, compatível com AES-256.

A derivação faz uso de salt aleatório por cofre e de um número fixo de iterações, aumentando a resistência do sistema contra ataques de dicionário e força bruta.

Os segredos são cifrados utilizando AES-GCM, um modo de operação autenticado que combina confidencialidade e integridade. O algoritmo usa:

- chave derivada da senha mestra;

- nonce aleatório de 12 bytes;
- texto cifrado;
- etiqueta de autenticação.

Além disso, o sistema utiliza AAD (Additional Authenticated Data) para garantir que a relação entre cofre e segredo seja autenticada.

A aplicação também cria um verificador da frase *cofre-ok* para validar a senha mestra correta do cofre. Qualquer adulteração dos registros é detectada e a operação é rejeitada antes que o conteúdo sensível seja devolvido.

5 Fluxo de Funcionamento

O fluxo principal da aplicação segue os seguintes passos:

1. O usuário cria um cofre e informa uma senha mestra;
2. o sistema gera um salt aleatório e deriva uma chave PBKDF2;
3. o verificador do cofre é cifrado e armazenado no banco;
4. o usuário cria um segredo com título, senha e dados opcionais;
5. o valor do segredo é cifrado com AES-GCM;
6. o banco armazena apenas os valores cifrados e metadados necessários;
7. para leitura ou atualização, o usuário envia a senha mestra no cabeçalho da requisição;
8. a API valida a senha, verifica a integridade do registro e retorna o valor solicitado.

6 Endpoints da API

A aplicação disponibiliza uma API REST com os principais endpoints:

- `POST /cofres`
- `POST /cofres/{cofre_id}/abrir`
- `POST /cofres/{cofre_id}/segredos`
- `GET /cofres/{cofre_id}/segredos`
- `GET /cofres/{cofre_id}/segredos/{segredo_id}`

- PUT /cofres/{cofre_id}/segredos/{segredo_id}
- DELETE /cofres/{cofre_id}/segredos/{segredo_id}

Todas as operações protegidas exigem o cabeçalho:

X-Senha-Mestra: <senha-mestra>

7 Tratamento de Erros e Segurança Operacional

A API foi implementada com mecanismos de validação e tratamento de erros, incluindo:

- resposta 401 para senha mestra inválida;
- resposta 404 para cofres ou segredos inexistentes;
- resposta 422 para entradas inválidas;
- resposta 500 para falhas internas ou registro adulterado.

Em caso de adulteração do registro, a aplicação retorna uma mensagem indicando falha de integridade, evitando a exposição do conteúdo sensível.

8 Testes e Validação

Para verificar o comportamento do sistema, foram desenvolvidos testes automatizados cobrindo os principais cenários da aplicação.

Os testes validaram:

- criação e abertura de cofres;
- autenticação correta e incorreta;
- criação, leitura, atualização e remoção de segredos;
- rejeição de dados adulterados;
- falha para segredos e cofres inexistentes;
- validação de payloads inválidos;
- suporte a valores com caracteres especiais;
- funcionamento da documentação OpenAPI da API.

Os testes foram executados com sucesso e o resultado obtido foi:

- 53 testes aprovados;
- 0 falhas.

9 Conclusão

O projeto desenvolvido atende aos principais requisitos de segurança para um sistema de armazenamento de senhas em ambiente didático e acadêmico.

A utilização de PBKDF2, AES-GCM, sal aleatório, nonce regenerado a cada operação e autenticação por senha mestra demonstra a aplicação prática de técnicas criptográficas essenciais para proteção de dados sensíveis.

Além disso, a solução apresenta uma arquitetura simples, modular e testável, permitindo manutenção e evolução futura. O sistema destaca-se pela separação entre autenticação, criptografia e persistência, o que reforça a organização do código e melhora a segurança do sistema.

Em conclusão, o cofre de senhas desenvolvido representa uma implementação funcional e segura de gerenciamento de segredos, sendo adequado para fins de estudo, demonstração de boas práticas e validação de conceitos de segurança da informação.